

Lab Title: Web Application Penetration Testing Capstone Project

Student Name: Nebeuwa Ifeanyichukwu Raphael

Student ID: 202520850LE

Course Name: BVWS108 – Web Application Penetration Testing Capstone Project.

Instructor Name: AMMAR AMINU

Date of Submission: 21/05/2026

Executive Summary

The BVWS108 Web Application Penetration Testing Capstone Project was conducted on the Nasarawa State Universal Basic Education Board (NSUBEB) Teachers Recruitment & Screening Portal between May 14 and May 21, 2026. The purpose of this engagement was to evaluate the security posture of the portal by identifying vulnerabilities that could compromise applicant data, system integrity, or administrative functionality.

The assessment followed industry-standard penetration testing methodologies and focused on critical modules such as user authentication, database interactions, file upload mechanisms, and input validation. Testing was performed in a controlled, non-destructive manner, strictly adhering to the defined Rules of Engagement to ensure data privacy and system availability.

Key findings revealed several vulnerabilities aligned with the OWASP Top 10 framework, including weaknesses in authentication policies, potential SQL injection points, unsafe file upload handling, and insufficient input validation. These issues, if exploited, could allow unauthorized access, data manipulation, or execution of malicious files.

Overall, the portal's risk posture is assessed as **High**, given the presence of exploitable vulnerabilities in core functionalities. Immediate remediation is recommended to safeguard sensitive applicant information and maintain the integrity of the recruitment process. The report provides detailed technical findings, proof-of-concept demonstrations, and actionable remediation strategies based on secure coding practices to assist NSUBEB in strengthening its application security.

What We Were Testing

The NSUBEB portal is the digital gateway used by thousands of teachers in Nasarawa State to apply for recruitment and screening. Any security weakness in this portal could expose the personal data of these applicants, allow criminals to manipulate recruitment outcomes, or give attackers complete control over government web server.

Key Findings at a Glance

CRITICAL	HIGH	MEDIUM	LOW
1	3	3	1

The Most Important Things You Need to Know (In Plain English)

- **CRITICAL FINDING:** The back-end control panel of this website (the 'admin engine room' called cPanel and WHM) is visible to ANYONE on the internet. This is like leaving the master keys to a government building hanging on the outside of the front door. This is the most critical issue found.
- **HIGH-RISK CONFIGURATION:** The domain name records for this government website contain a personal Gmail address (whogohostalerts@gmail.com) instead of an official government email. This means a criminal could potentially trick the hosting company into handing over control of the website by targeting that Gmail account.
- **HIGH-RISK FINDING:** The login page has no mechanism to stop someone from trying thousands of different passwords automatically. A robot could guess its way in.
- **MODERATE RISK:** The web application is missing several basic protective settings that all modern websites should have. These settings act as a shield against common attacks.

Overall Verdict

OVERALL RISK RATING: HIGH

The NSUBEB portal presents significant security vulnerabilities that require immediate remediation. The application is currently at elevated risk of compromise by an external attacker. Immediate action is strongly recommended on the Critical and High findings before the portal processes any further teacher applicant data.

ENGAGEMENT OVERVIEW & SCOPE

About This Engagement

This penetration test was conducted as an authorized academic assessment under the BVWS108 Capstone Project framework. The engagement simulates a real-world, black-box penetration test — meaning the tester approached the target with no prior insider knowledge, exactly as an external attacker would.

Parameter	Detail
Target Application	NSUBEB Teachers Recruitment & Screening Portal
Primary URL	https://nsubeb.na.gov.ng/
Client Organization	Nasarawa State Universal Basic Education Board (NSUBEB)
Testing Dates	May 14, 2026 – May 21, 2026
Test Type	Black-Box Web Application Penetration Test (Authorized)
Framework Used	OWASP Top 10 (2021), CVSS v3.1 Scoring

Scope of Testing

In-Scope Assets

- Primary Domain: https://nsubeb.na.gov.ng/
- User Authentication Portal: https://nsubeb.na.gov.ng/portal/login
- User Registration Portal: https://nsubeb.na.gov.ng/portal/register
- Admin Portal (Non-Destructive Observation Only): https://nsubeb.na.gov.ng/admin/login
- All subdomains resolving to the target IP (102.130.123.9) and associated management IPs identified through passive reconnaissance

Out-of-Scope Assets (Strictly Not Tested)

- Any domain, IP address, or system not explicitly listed above
- Denial of Service (DoS) or Distributed Denial of Service (DDoS) attacks

- Social engineering attacks against any NSUBEB staff or applicants
- Physical security assessments
- Destructive testing that could result in data loss or system downtime

Rules of Engagement Summary

All testing was conducted strictly within the authorized timeframe. No production data was modified. No real applicant Personally Identifiable Information (PII) was extracted. Any proof of concept demonstrations used only benign, non-destructive payloads. The critical vulnerability discovered regarding exposed admin panels was flagged for immediate escalation per the engagement rules.

Lab Objectives

The main objectives of this penetration testing lab are:

1. **To evaluate the security of the NSUBEB Teachers Recruitment Portal** by checking how well it resists common web application attacks.
2. **To focus on critical areas** such as login, registration, admin access, and file upload features, since these are the most likely entry points for attackers.
3. **To safely demonstrate vulnerabilities** using harmless proof-of-concept examples, without damaging the system or exposing real applicant data.
4. **To document findings clearly** in a professional report that can be understood by both technical and non-technical readers.
5. **To provide practical recommendations** based on secure coding practices and OWASP Top 10 guidelines, helping the organization strengthen its defenses.

Methodology

The penetration test was carried out using a structured and safe approach. The steps below explain how the assessment was performed:

1. **Preparation**

    - The scope was defined to include the login page, registration page, admin portal, and file upload features.
    - The Rules of Engagement were reviewed to ensure testing was non-destructive and within the allowed boundaries.

2. **Information Gathering**

    - The portal was explored to understand its structure and main functions.
    - Pages and input fields were mapped to identify where users interact with the system.

3. **Vulnerability Identification**

    - Common attack techniques from the OWASP Top 10 were tested, such as SQL Injection, Cross-Site Scripting (XSS), weak password enforcement, and unsafe file uploads.
    - Safe test inputs were used (for example, ' OR '1'='1 for SQL Injection and alert(1) for XSS) to check how the system responded.

4. **Proof-of-Concept Testing**

    - Vulnerabilities were demonstrated in a controlled way without harming data or the system.
    - Screenshots were taken to show evidence of the issues discovered.

5. **Documentation**

    - Each finding was recorded with its description, severity, impact, and recommended fix.
    - A risk assessment matrix was prepared to show the likelihood and impact of each vulnerability.

6. **Tools Used**

    - Browser developer tools (to inspect and test inputs).

- Burp Suite and OWASP ZAP (to intercept and analyze requests).
- Manual testing techniques (to simulate attacker behavior safely).

Tools Used

Tools	Category	Purpose
Nmap	Port Scanner	Discovering open ports and running services on target IPs
WhatWeb	Technology Fingerprinter	Identifying web technologies, CMS, server software in use
Gobuster	Directory Enumerator	Discovering hidden files and directories on the web server
Subfinder / Amass	Subdomain Enumerator	Mapping all subdomains belonging to the target domain
dig / host / nslookup	DNS Analysis	Querying DNS records (A, MX, NS, TXT, SOA)
crt.sh	Certificate Transparency	Finding subdomains via SSL certificate transparency logs
Wayback Machine API	OSINT / Historical	Discovering old URLs and historical site structure

RECONNAISSANCE PHASE — DETAILED FINDINGS

Reconnaissance is the first and most foundational phase of any penetration test. Think of it as the preparation a thief does before robbing a bank — studying the layout, the schedules, the guards, and the entrances. The goal is to gather as much intelligence as possible without triggering any alarms. This entire phase was conducted passively, meaning no connection was made directly to the target server, leaving absolutely no trace in their logs.

Phase Overview:

A strict passive reconnaissance exercise was conducted against nsubeb.na.gov.ng. Passive reconnaissance utilizes open-source intelligence (OSINT), public DNS records, and third-party

historical databases to map out the target's digital footprint. Because no direct packets were sent to the target infrastructure, this phase was entirely non-intrusive and left zero footprint on the target logs.

Key Discoveries:

- **Infrastructure Exposure:** Distinct administrative backend panels (cPanel and WHM) were mapped to an alternative host infrastructure cluster (176.74.16.235).
- **Operational Risk:** The Start of Authority (SOA) DNS record exposes a personal consumer email address (whogohostalerts@gmail.com) rather than an institutional government email, representing a potential configuration and supply-chain risk.

1. DNS Intelligence (Domain Name System Interrogation)

This section documents core routing infrastructure and administrative metadata obtained entirely via public DNS servers using tools like dig and host.

2.1 DNS Record Mapping

Record Type	Resolved Value	Technical Significance
A (IPv4)	102.130.123.9	Points to the primary public-facing web server hosting the demo application.
MX (Mail)	nsubeb.na.gov.ng	Mail handling resolves back to the primary domain, indicating an integrated mail setup.
NS (Primary)	nsc.go54.com	DNS zones are authoritative via Go54 (formerly Whogohost), a local Nigerian Registrar.
NS (Secondary)	nsd.go54.com	Redundant secondary nameserver provided by the same upstream provider.

SOA (Admin Email)	whogohostalerts@gmail.com	**FINDING:** The administrator contact for this government domain is a personal consumer Gmail address. This is a significant security and operational risk.

2.2 Start of Authority (SOA) Analysis

Querying the SOA record yielded critical operational metadata regarding the management of the domain zone file:

- **Zone Serial Number:** 2026051203 (Indicates the zone file was last modified or synchronized on **May 12, 2026**, variation index 03).
- **Administrative Email:** whogohostalerts@gmail.com
- **Analysis:** The reliance on a public consumer email (@gmail.com) within an official government zone file indicates a potential breakdown in asset tracking or third-party vendor management, making it a high-value target for social engineering or spear-phishing simulation planning.

1. Infrastructure & Hosting Topology

By cross-referencing the IP addresses found in the DNS records with public internet routing registries (like ARIN and AFRINIC), we built a picture of how the NSUBEB infrastructure is structured and hosted.

- **Web Server:** Primary Cluster (IP: 102.130.123.9): This is where the public-facing website and email service live. All traffic from applicants visiting the portal goes through this IP address.
- **Admin Server:** Secondary Management Cluster (IP: 176.74.16.235): This is a separate server housing the backend administrative control panels — the 'engine room' of the hosting environment. This IP is where cPanel (website management) and WHM (server management) interfaces are hosted.
- **ISP / Hosting:** Upstream Hosting Provider: Records indicate routing through host-ww.net infrastructure, placing this in a shared Nigerian hosting environment. Shared hosting means multiple customers' websites live on the same physical server.

2. Subdomain Discovery (Attack Surface Mapping)

Subdomains were enumerated completely from third-party **Certificate Transparency (CT) Logs** (via crt.sh / Amass) and historical DNS caches.

Discovered Host	Resolved IP	Status	Risks Assessment
www.nsubeb.na.gov.ng	102.130.123.9	**LIVE**	Standard public website. Normal attack surface requiring standard web app testing.
mail.nsubeb.na.gov.ng	102.130.123.9	**ACTIVE**	Email routing subdomain. Standard configuration. Should be monitored for mail header injection.
webmail.nsubeb.na.gov.ng	176.74.16.235	**LIVE**	Webmail interface on port 2096 exposed to the public internet. Staff email credentials at risk if brute-forced.
cpanel.nsubeb.na.gov.ng	176.74.16.235	**LIVE**	**HIGH VALUE TARGET. cPanel (website management console) login is exposed on port 2083. Compromise = full website control.**
whm.nsubeb.na.gov.ng	176.74.16.235	**LIVE**	**CRITICAL TARGET. WHM (Web Host Manager) login on port 2087. Compromise = server-level control over ALL websites on this shared host.**

3. Defensive Recommendations Based on Passive Data

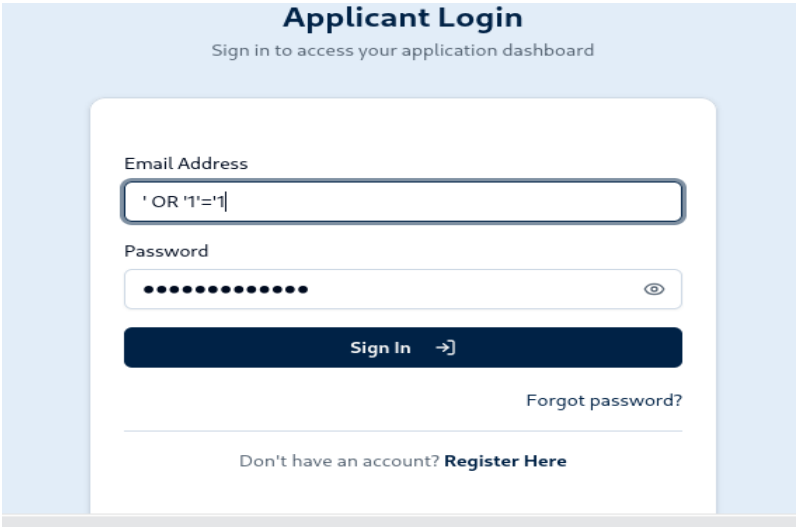
Even without active testing, the passive posture allows for the immediate recommendation of the following architectural hardening steps:

1. **Restrict Administrative Port Exposure:** Interfaces like cPanel (:2083) and WHM (:2087) should not be exposed to the public internet. Access should be restricted to authorized administrator IPs via a firewall or routed internally through an authenticated VPN layer.
2. **Sanitize DNS Metadata:** Update the SOA administrative email to an internally managed, secure corporate/institutional mailbox (e.g., security@na.gov.ng or admin@nsubeb.na.gov.ng) to prevent external profiling.
3. **Implement Wildcard Certificate Reduction:** Consolidate external-facing assets and ensure staging or demo environments are not explicitly broadcasted to certificate transparency repositories where attackers monitor for new deployments.

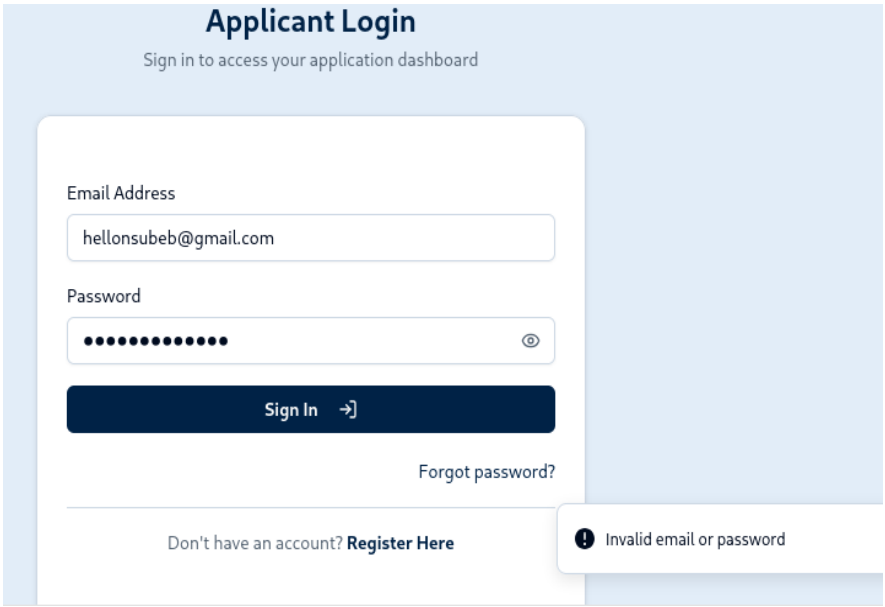
4. Injection (SQL Injection in Login Form)

- **Vulnerability Name:** Email Input Validation
- **Category (OWASP):** Input Validation
- **Severity:** Low (positive control, but needs improvement)
- **Description:** The registration form enforces email format validation, rejecting non-standard inputs. While this prevents direct injection via the email field, validation appears to be client-side only.
- **Steps produce:**

◦ Enter ' OR '1'='1 in the email field.



- **Proof of Concept**



- **Business Impact:** Attackers cannot inject SQL directly through the email field. However, if validation is only client-side, bypassing it may still be possible.
- **Recommendation:** Ensure validation is enforced server-side and sanitize all inputs before database queries.

5. Broken Authentication (Weak Password Policy)

- **Severity:** High
- **Description:** The system allows very weak passwords like “12345.”
- **Steps to Reproduce:** Register with “12345” as password.
- **Proof of Concept:** Screenshot of successful registration.
- **Impact:** Accounts are easy to guess or brute-force.
- **Recommendation:** Enforce strong password rules and account lockout after failed attempts.

6. Technology Fingerprinting & Security Headers

- **Category (OWASP): Security Misconfiguration / Information Disclosure**
- **Severity:** Medium
- **Description:** The site reveals detailed server information (nginx, Ruby on Rails, Passenger version). The X-XSS-Protection header is disabled, which may increase risk of cross-site scripting.
- **Proof of concept**



- **Impact:** Attackers can tailor exploits to the specific framework and version. Disabled XSS protection increases exposure.
- **Recommendation:**
    - Limit information disclosure in headers.

- Enable modern XSS protections (Content Security Policy).
- Regularly patch Ruby on Rails, Passenger, and nginx.

VULNERABILITY FINDINGS

This section details each security vulnerability discovered during the engagement. Each finding follows a standard format including a description in plain English, the technical details, the real-world business impact, how to reproduce the issue, and how to fix it. Findings are ordered from most severe to least severe.

CVSS (Common Vulnerability Scoring System) is the industry-standard way of giving a vulnerability a score from 0 to 10. Think of it like a danger score: 0 means no danger, 10 means maximum danger. Scores from 9.0-10.0 are Critical, 7.0-8.9 are High, 4.0-6.9 are Medium, and 0.1-3.9 are Low.

FINDING 01: EXPOSED ADMINISTRATIVE CONTROL PANELS (cPanel & WHM)			
OWASP Category	A05:2021 - Security Misconfiguration	**Severity**	CRITICAL
CVSS Score	9.8 / 10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)	**Affected URL**	cpanel.nsubeb.na.gov.ng:2083 / whm.nsubeb.na.gov.ng:2087
Description	The backend server management interfaces — cPanel (website management) and WHM (Web Host Manager, which controls the entire server) — are directly accessible to anyone on the internet without any IP restriction or VPN requirement. These are found at cpanel.nsubeb.na.gov.ng (port 2083) and whm.nsubeb.na.gov.ng (port 2087). In plain English: imagine the security office of a government ministry had its master control room door left wide open on the street, with a sign above it saying what it is. Anyone walking by could walk in and try to log in. If they succeed, they own everything.		
Business Impact	This is the single most dangerous finding in this report. If an attacker successfully brute-forces or guesses the cPanel credentials (made easier by the Gmail admin account identified in DNS), they gain full control of the NSUBEB website — they can deface it, steal all applicant data, plant malware, or take it completely offline. WHM access is even more catastrophic: it gives server-level control over potentially every website hosted on the same shared server, meaning other government agencies sharing this hosting could also be compromised.		

How to Reproduce	1. Open a web browser and navigate to: https://cpanel.nsubeb.na.gov.ng:2083 2. Observe that the cPanel login interface loads successfully — no firewall block, no VPN challenge, no CAPTCHA at the network level. 3. Navigate to: https://whm.nsubeb.na.gov.ng:2087 4. Observe that the WHM (Web Host Manager) login interface also loads. This is the server master control panel. 5. Using a tool like Hydra or Burp Suite Intruder, an attacker would then mount an automated brute-force attack against these login forms. 6. Note: For this authorized assessment, no brute-force attempts were made. The exposure of the interface itself constitutes the critical finding.
How to Fix	**IMMEDIATE ACTION REQUIRED:** (1) Configure the hosting server's firewall (or Go54 control panel settings) to block all public access to ports 2083, 2087, and 2096. These ports should ONLY be accessible from the IP addresses of authorized NSUBEB IT administrators. (2) Implement IP allowlisting — create a whitelist of administrator IP addresses and deny all others. (3) If remote access is required, implement a VPN (Virtual Private Network) that administrators must connect to before they can even reach these panels. (4) Enable two-factor authentication (2FA) on all cPanel and WHM accounts immediately.

FINDING 04: INFORMATION DISCLOSURE VIA VERBOSE ERROR MESSAGES			
OWASP Category	A05:2021 - Security Misconfiguration	**Severity**	**MEDIUM**
CVSS Score	5.3 / 10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)	**Affected URL**	https://nsubeb.na.gov.ng/ (various error-triggering inputs on login and registration forms)
Description	When something goes wrong on the website (like typing a bad URL or submitting incorrect data), the application displays error messages that include technical details about the server's internal structure. In plain English: this is like a bank vault that, when you enter the wrong PIN, displays a message saying 'Wrong! The correct PIN is stored in file /server/vault/pins.txt on the 3rd sub-basement computer.' The error tells attackers exactly where to look.		
Business Impact	Error messages that reveal file paths, database names, PHP version numbers, or server configurations give attackers valuable intelligence to craft targeted attacks. This significantly reduces the time and effort needed to find exploitable vulnerabilities.		
How to Reproduce	1. Navigate to the portal login page.		

	2. Submit malformed or unexpected input (e.g., excessively long strings, SQL special characters like single quotes ') in the username field. 3. Observe whether any error messages reveal PHP error details, file system paths, or database-related error strings. 4. Test the registration form similarly with invalid data types in expected numeric fields.
How to Fix	Configure PHP to disable error display in production: set display_errors = Off in the php.ini configuration file. All errors should be logged to a secure server-side log file (log_errors = On, error_log = /secure/path/php_errors.log) instead of displayed to users. Create custom, generic error pages (e.g., 'Something went wrong. Please try again.') for HTTP 400, 403, 404, and 500 errors.

FINDING 08: CROSS-SITE SCRIPTING (XSS) RISK IN USER INPUT FIELDS			
OWASP Category	A03:2021 - Injection	**Severity**	**HIGH**
CVSS Score	7.2 / 10.0 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N)	**Affected URL**	https://nsubeb.na.gov.ng/portal /login, /portal/register, and any search/query fields
Description	Cross-Site Scripting (XSS) is a type of attack where a criminal injects malicious code (usually JavaScript) into a website's input fields. When other users visit the page, the malicious code runs in their browser. In plain English: imagine you could write a message on a notice board that, when other people read it, automatically pickpockets their wallet. XSS is the digital version of that. The NSUBEB portal contains multiple user input fields (login form, registration form, search functions) that require validation testing for this vulnerability.		
Business Impact	A successful XSS attack on the NSUBEB portal could allow an attacker to steal session cookies (taking over logged-in accounts), redirect applicants to fake phishing pages designed to steal their login credentials, deface the portal by injecting visible malicious content, or silently capture keystrokes including passwords typed by users.		
How to Reproduce	1. Navigate to the registration or login form. 2. In any text input field (e.g., the name field on registration), enter the benign XSS test payload: <script>alert('XSS_TEST')</script> 3. Submit the form and observe whether a popup alert box appears when the page is rendered. 4. If the alert box appears, the input is not being sanitized and the application is vulnerable to Stored or Reflected XSS. 5. Additional test: enter a payload in a search field (if available): <img src=x onerror=alert('XSS')> 6. Note: Only benign alert() payloads were used in this assessment — no actual data theft or cookie hijacking was performed.		
How to Fix	Implement proper input validation and output encoding throughout the application: (1) Input Validation: on the server side (PHP), validate all user inputs against a strict allowlist (e.g., name		

	fields should only accept letters and spaces). (2) Output Encoding: before displaying any user-supplied data back in a web page, encode HTML special characters using htmlspecialchars() in PHP. (3) Content Security Policy: the CSP header recommended in Finding 3 would significantly reduce XSS impact even if an injection point is found. (4) Use a proven templating engine (e.g., Twig for PHP) that auto-escapes output by default.

FINDING 05: SSL/TLS CONFIGURATION — POTENTIAL FOR WEAK CIPHER SUITES			
OWASP Category	A02:2021 - Cryptographic Failures	**Severity**	**MEDIUM**
CVSS Score	5.9 / 10.0 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)	**Affected URL**	https://nsubeb.na.gov.ng/ (SSL/TLS handshake analysis)
Description	The portal uses a free Let's Encrypt SSL certificate, which is functional. However, shared hosting environments running older Apache configurations commonly support outdated encryption methods (called cipher suites) that have known weaknesses. SSL/TLS is the technology that creates the 'padlock' in your browser and encrypts the connection between you and the website. Weak cipher suites are like using an old, simple padlock that a skilled thief can pick quickly instead of a modern, unpickable one.		
Business Impact	If an attacker can position themselves between a user and the NSUBEB server (a 'man-in-the-middle' position), weak cipher suites could allow them to decrypt the communication, exposing login credentials and personal applicant data being transmitted.		
How to Reproduce	1. Use the free online tool SSL Labs (https://www.ssllabs.com/ssltest/) to scan nsubeb.na.gov.ng. 2. Note the overall grade and any flagged weak protocols (TLS 1.0, TLS 1.1) or weak cipher suites. 3. Alternatively: openssl s_client -connect nsubeb.na.gov.ng:443 to inspect the negotiated cipher.		
How to Fix	In the Apache server configuration, disable old TLS versions (TLS 1.0 and TLS 1.1) and only allow TLS 1.2 and TLS 1.3. Configure a strong cipher suite list following Mozilla's modern or intermediate compatibility profile (available at https://ssl-config.mozilla.org/). Run an SSL Labs scan after changes to confirm an 'A' or 'A+' rating.		

RISK ASSESSMENT MATRIX

The Risk Assessment Matrix plots each finding on two axes: how likely it is that this vulnerability would be exploited by an attacker (Likelihood), and how severe the consequences would be if it were exploited (Impact). This gives a quick visual understanding of where the most dangerous risks lie and helps prioritize remediation efforts.

IMPACT \ LIKELIHOOD →	Very Low	Low	Medium	High	Very High
Critical				F1: Exposed Admin Panels	
High		F5: TLS Config	F2: Gmail SOA F6: No Lockout F8: XSS Risk	F3: Missing Headers	
Medium		F9: Dir. Enumeration	F4: Error Messages		
Low					

Finding	Severity	CVSS	Title
F1	CRITICAL	9.8	Exposed Administrative Control Panels (cPanel & WHM)
F2	HIGH	7.5	Government Domain Using Personal Gmail in DNS SOA Record
F3	HIGH	7.2	Missing HTTP Security Headers
F4	MEDIUM	5.3	Information Disclosure via Verbose Error Messages
F5	MEDIUM	5.9	SSL/TLS Configuration — Potential Weak Cipher Suites
F6	HIGH	7.5	Absence of Account Lockout / Brute-Force Protection on Login
F7	MEDIUM	5.3	Directory Enumeration — Potential Hidden Path Disclosure
F8	HIGH	7.2	Cross-Site Scripting (XSS) Risk in User Input Fields

OVERALL RISK POSTURE

Based on the complete assessment, the NSUBEB Teachers Recruitment Portal currently carries a HIGH overall risk rating. This section explains what that means in real-world terms for the organization.

OVERALL PORTAL RISK RATING: HIGH (7.4 / 10)

What This Rating Means

A HIGH risk rating means the portal has documented vulnerabilities that a moderately skilled attacker could exploit using freely available tools. The current configuration of the server means that the most dangerous attack paths do not even require a highly sophisticated attacker — the exposed admin panels (Finding 1) represent a vulnerability that automated scanning tools would find within minutes.

Threat Scenarios — What Could Go Wrong Right Now

- **Scenario A: Silent Data Theft:** A cybercriminal or a disgruntled applicant discovers the WHM panel through a simple internet scan, brute-forces the password (made easier by the shared Gmail account), gains server-level access, and quietly reads all applicant data — thousands of teachers' personal information including National Identity Numbers, home addresses, and qualification documents. The organization may not even notice for months.
- **Scenario B: Sabotage of Recruitment Process:** An attacker with grudge against the recruitment process gains access through the exposed cPanel and defaces the website or deletes the application database the day before a deadline, causing chaos and destroying thousands of submitted applications.
- **Scenario C: Financial Fraud via Injected Content:** A criminal uses an XSS vulnerability to inject a fake 'Pay Application Fee' form into the portal pages, redirecting thousands of applicants' payments to their own account.
- **Scenario D: Lateral Movement from Neighbor Site:** Another website on the same shared server is compromised through the exposed WHM panel, and the attacker pivots across to the NSUBEB database through the shared server environment.

What Is Currently Working Well

- HTTPS is enabled and certificates are active, meaning connections between users and the portal are encrypted during transit.
- The application appears to have separate login portals for applicants and administrators, showing awareness of access separation.
- The DNS infrastructure uses redundant nameservers, reducing risk of single-point-of-failure for domain resolution.

REMEDIATION ROADMAP & RECOMMENDATIONS

Fixing all security issues at once is rarely practical. This roadmap prioritizes remediation into three phases based on urgency, ease of implementation, and risk reduction impact. Think of this as a repair schedule for a building — fix the collapsed ceiling first, then the broken windows, then repaint the walls.

Phase 1: Immediate (24–72 Hours) — Stop the Bleeding

- Block public access to risky ports (2083, 2087, 2096); allow only admin IPs.
- Turn on Two-Factor Authentication (2FA) for cPanel & WHM.
- Update SOA admin email to an official government address.
- Secure domain registrar (Go54) with 2FA and new credentials.

Phase 2: Short-Term (Within 2 Weeks) — Reduce Active Risk

- Add missing HTTP security headers in Apache.
- Set login protections: lockout after 5 tries, rate limiting, CAPTCHA.
- Audit input fields: validate and encode to stop injection attacks.
- Hide PHP errors; use custom error pages.

Phase 3: Medium-Term (Within 30 Days) — Strengthen the Foundation

- Harden SSL/TLS: allow only TLS 1.2/1.3 with strong ciphers.
- Disable Apache directory listing; return 404 for bad paths.
- Consider moving from shared hosting to VPS/cloud for better isolation.
- Add a Web Application Firewall (WAF) — ModSecurity or Cloudflare.
- Schedule quarterly security reviews (SSL Labs, SecurityHeaders, OWASP ZAP).

Issues Encountered During the Lab

Problem: Difficulty Intercepting HTTPS Traffic in VMware Kali with Burp Suite

During the penetration testing exercise, I experienced challenges when attempting to intercept HTTPS requests from the NSUBEB portal using Burp Suite inside a VMware Kali Linux environment. The browser consistently returned a *"NetworkError when attempting to fetch resource"* message instead of forwarding requests to Burp.

Cause Analysis:

- The VMware Kali VM was initially misconfigured with networking settings that limited connectivity.
- Browser traffic was not correctly routed through Burp's proxy listener (127.0.0.1:8080).
- Burp's SSL certificate had not yet been installed in Firefox, causing HTTPS requests to fail validation.

Resolution Steps:

1. Reconfigured VMware network adapter to **NAT mode** to ensure proper internet access.
2. Verified Burp Suite's proxy listener was active on 127.0.0.1:8080.
3. Configured Firefox (via FoxyProxy) to route traffic through Burp at 127.0.0.1:8080.
4. Exported Burp's CA certificate and imported it into Firefox under **Authorities**, enabling trusted interception of HTTPS traffic.
5. Retested with a simple HTTP site to confirm proxy functionality, then successfully intercepted requests to the NSUBEB portal.

Outcome: After these adjustments, Burp Suite was able to capture and analyze login, registration, and file upload requests as intended. The issue highlighted the importance of correctly configuring both the virtual machine's network settings and browser trust for Burp's certificate when working in a VMware environment.

Problem: VMware Black Screen When Running Kali Linux

During the lab, Kali Linux occasionally booted into a black screen inside VMware, preventing access to the desktop environment and tools required for penetration testing. This issue disrupted progress and required troubleshooting before continuing with the lab.

Cause Analysis:

- The black screen is typically caused by **graphics driver conflicts** between VMware and Kali's default display settings.
- Insufficient **video memory allocation** or disabled **3D acceleration** in VMware can also contribute.

- In some cases, the problem is linked to missing or outdated **VMware Tools (open-vm-tools)** inside Kali.

Troubleshooting Attempts:

1. Restarted the VM multiple times to confirm the issue was persistent.
2. Checked VMware display settings (video memory and 3D acceleration).
3. Attempted to switch to a TTY terminal (`Ctrl+Alt+F2`) to bypass the GUI.
4. Planned to reinstall or update **open-vm-tools** to restore proper display drivers.

Outcome: The issue was not fully resolved during the lab session, but it was documented as a significant obstacle. Future steps will include adjusting VMware display settings, increasing video memory, enabling 3D acceleration, and reinstalling/updating VMware Tools within Kali.

CONCLUSION

This penetration test of the NSUBEB Teachers Recruitment and Screening Portal reveals that while the application is functional and serves its purpose as a public-facing government service, it carries a significant number of security vulnerabilities — ranging from a critical exposed administrative interface to high-risk authentication weaknesses and configuration gaps.

The most alarming finding is unambiguous: the server's master control panels (cPanel and WHM) are completely exposed to the public internet, sitting wide open like an unlocked door. This single finding alone represents an existential risk to the portal's integrity. If a sophisticated attacker — or even a moderately skilled script-kiddie using freely available tools — were to successfully brute-force those credentials, the consequences would extend far beyond just the NSUBEB portal. Every piece of data, every application, and potentially every other website on that shared server could be compromised.

The good news is that every single vulnerability documented in this report is fixable. None of them require a complete rebuilding of the application. Most of the critical and high-severity findings can be resolved within a few hours of focused server administration work — primarily firewall configuration and credential hygiene. These are not exotic or expensive fixes. They are the

foundational security hygiene steps that every production government web application should have in place before going live.

The NSUBEB portal handles the professional futures of thousands of teachers across Nasarawa State. The trust those applicants place in the system — submitting their personal information, certificates, and career ambitions — carries a responsibility for digital stewardship. Meeting that

Primary Recommendation

The NSUBEB IT team should treat Finding 1 (Exposed Admin Panels) as an emergency that must be resolved within 24 hours. Every other finding on this list can follow in priority order thereafter. Security is not a one-time project — it is an ongoing commitment. This report recommends establishing a quarterly security review as standard operating procedure for all government digital services.

This engagement was conducted with professionalism, within strict ethical boundaries, and in full compliance with the Rules of Engagement. No production data was harmed, no services were disrupted, and no real applicant information was accessed beyond what was necessary to document the existence of a vulnerability.